

Vulnerability Management

-  Home
-  Documentation
- <> API Reference
-  Code Samples
-  Announcements
- Models
- Release Notes
- FAQ
- GitHub
- Videos

GET STARTED

- Welcome to SP-API Documentation
- What is the Selling Partner API?
- Selling Partner API Onboarding Overview >

- Terminology
- Frequently Asked Questions >

CHANGELOG

- SP-API Release Notes
- SP-API Deprecation Schedule

Vulnerability Management

Learn how to implement effective vulnerability management practices including regular scans, penetration testing, and disaster recovery planning.

Solution providers must implement vulnerability scans at minimum every 30 days, penetration tests yearly, code vulnerability scans prior to release of new code, features, or products, and to ensure they can restore availability and access to personally identifiable information (PII) within hours.

This guide outlines mandatory vulnerability management requirements and implementation guidance such as vulnerability scans, penetration tests, and code vulnerability scans. This guide also explores processes to restore availability and access after a service interruption due to an incident.

Amazon Data Protection Policy (DPP) requirements

The Amazon Data Protection Policy contains two categories related to security requirements:

- **Section 1. General Security Requirements**, which includes requirements for all solution providers building SP-API applications.
- **Section 2. Additional Security Requirements for Personally Identifiable Information (PII)**, which includes additional requirements for solutions providers performing restricted operations on SP-API that involve personally identifiable information (PII).

To comply with the vulnerability management requirements in the DPP, solutions providers

SP-API Product Metadata Updates	
DIRECTORIES	
SP-API Models	
SP-API Seller Use Cases	
SP-API Vendor Use Cases	
Seller Central URLs	
Vendor Central URLs	
REGISTRATION	
SP-API Registration Overview	>
Developer Registration Request Status	
Third-Party Provider Registration	>
Service Provider Registration and Role Approval Process Overview	
Website Guidelines for Public Developers and Service Providers	
User Permissions for Service Providers	
Register your Application	
Update your Application Information	
Rotate your Application's LWA Credentials	>
View your Application Information and Credentials	
Learn How Sellers Authorize Service Providers	
Selling Partner API Roles	>
Policies and Agreements	
About Facial Data	
AUTHORIZATION	
Authorize Applications	>
Renew Authorizations	
Revoke Authorizations	
Authorization Limits	

must:

- Create and maintain a plan to detect and resolve vulnerabilities.
- Conduct vulnerability scans every **30 days**.
- Conduct penetration tests every **365 days**.
- Scan code for vulnerabilities **prior to every release**.
- Resolve critical-risk vulnerabilities within **seven days** of discovery.
- Resolve high-risk vulnerabilities within **30 days** of discovery.
- Maintain periodic backups, secondary backup sites, backup-and-restore testing documentation, and ensure rapid data restoration capabilities.
- Maintain a geographically separated secondary/backup site.

Vulnerability scans

A vulnerability scan identifies, analyzes, and reports security weaknesses in hosts, networks, and applications.

Solution providers must verify that public facing devices/instances are protected against malicious actors. To identify risks and possible attack vectors within the network, solution providers must run scans with vulnerability scanning tools.

The following is a list of the top ten vulnerabilities, according to the Open Web Application Security Project ([OWASP](#)) for 2025 and associated Common Weakness Enumerations (CWE):

CWE	Vulnerability point	Brief description
A01	Broken access control	User performs an action they are not supposed to be able to access.
A02	Cryptographic failures	Lack of or weak cryptographic practices.

Special Authorization Types

>

INTEGRATION

Building Robust Amazon SP-API Applications

SP-API SDKs

>

Delete an Application From Your Developer Account

CALLING THE SP-API

Configuration Details

>

Call Structure

>

Development Tools

>

Performance Management

>

CWE	Vulnerability point	Brief description
A03	Injection	Hackers are able to insert data and manipulate it within a network.
A04	Insecure design	Lack of planning during the network design stage.
A05	Security misconfigurations	Security settings in databases, libraries, or servers not set, which could lead to a vulnerability.
A06	Vulnerable and outdated components	Legacy or unsupported versions of software or an operating system.
A07	Identification and authentication failures	Lack of user access controls and credential management.
A08	Software and data integrity failures	No protection against integrity violations.
A09	Secure logging and monitoring failure	No monitoring service making it difficult to identify breaches and outgoing attacks.
A10	Server-side request forgery (SSRF)	Unverified URL supplied by a user which coerces

SOLUTION PROVIDER PORTAL

Manage Users in Solution Provider Portal

Manage Your Business And Contact information in Solution Provider Portal

Update Your Developer Profile in Solution Provider Portal

Unify Your Developer Accounts

Verify Your Identity in Solution Provider Portal

API Usage Metrics in Solution Provider Portal

TUTORIALS

Tutorial: Subscribe to the ORDER_CHANGE Notification

Tutorial: Test Selling Partner API Endpoints

Tutorial: Automate your SP-API Calls Using a C# SDK

Tutorial: Automate your SP-API Calls Using a Java SDK

Tutorial: Automate your SP-API Calls Using a JavaScript SDK for Node.js

Tutorial: Automate your SP-API Calls Using a Python SDK

Tutorial: Automate your SP-API Calls using a prebuilt C# SDK

Tutorial: Automate your SP-API Calls using prebuilt Java SDK

Tutorial: Automate your SP-API Calls using a prebuilt JavaScript SDK

Tutorial: Automate your SP-API Calls using prebuilt PHP SDK

Tutorial: Automate your SP-API calls using a prebuilt Python SDK

Tutorial: Authorize Multiple Vendor Central Accounts with a Single SP-API Application

Tutorial: Retrieve Merchant Shipping Templates

Tutorial: Grant the SP-API Permission to an Amazon SQS Queue

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier

TROUBLESHOOTING

Troubleshoot SP-API Errors

URL Encoding

Resolve Common HTTP and Authorization Error Codes

External Fulfillment Errors 

Listings Items API Issues Troubleshooting 

SELLING PARTNER APPSTORE

What is the Selling Partner Appstore?

List Your App on the Selling Partner Appstore

CWE	Vulnerability point	Brief description
		an application to send requests that bypass network security.

For a list of free and paid scanning tools, refer to [OWASP – Vulnerability Scanning Tools](#).

After the scans are complete, solutions providers must prioritize vulnerabilities according to the level of security impact and work to remediate those accordingly.

- **External vulnerability scans:** External scans are meant to check vulnerabilities in external/public points such as ports, websites, networks, and applications.
- **Internal vulnerability scans:** Internal scans give visibility on possible security gaps within a private network.
- **Intrusive and non-intrusive scans:** Non-intrusive scans will scan a specific target, such as network traffic or a database's version, but it does not affect service levels as it only checks the information without taking advantage of the vulnerability. An intrusive scan is meant to exploit the vulnerability at its highest level and provide more insight about the vulnerabilities found, but it also interrupts service levels, so use it in a controlled environment.

Amazon Inspector

[Amazon Inspector](#) is a scalable vulnerability management tool which scans workloads and unintended network exposures to verify that there are no vulnerabilities in operating systems running EC2 instances.

Amazon Inspector provides near real-time vulnerability finding reports using updated Common Vulnerabilities and Exposure (CVE) factors and checking different coding languages such as Java, Python, and Node.js. Solutions providers that use Amazon Inspector can use it for compliance validation of programs such as PCI, ISO, and CSA STAR certificates.

Edit Your Appstore Listing
Check Listing Status
Appstore Ratings and Reviews
Press Releases and Promotions

SERVICE PROVIDER NETWORK

List Your Service

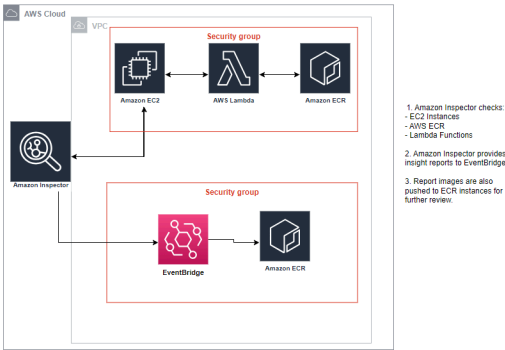
SECURITY AND COMPLIANCE

SP-API Security and Compliance Overview

Amazon Selling Partner API Guard Implementation Guide

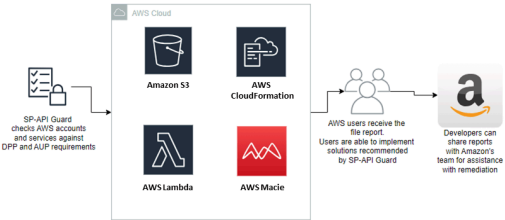


Vulnerability Management



Amazon Guard

Amazon's Security team developed [Amazon's SP-API Guard](#) as an application that runs in AWS instances to check and asses security compliance with [Amazon's DPP](#). SP-API Guard also provides a recommendation report of any security gap it finds within a day to an S3 bucket. This reduces the effort for manual Data Security Assessments and remediation plan times while providing recommended solutions for vulnerabilities found.



VAT Calculation Service



Penetration testing

Penetration testing (pen testing) is a way to check in a simulated/controlled environment for any vulnerabilities in different points of applications or networks. This is done to confirm which vulnerabilities can be exploited by bad actors. Solution providers must conduct penetration testing every 365 days.

Pen testing consists of the following stages:

- **Planning Stage:** The team sets goals and the scope for the testers' pen tests. All parties must be aware of the upcoming tests.
- **Scan/Discovery Stage:** Pen testers initiate the process of network recognition and code inspection.
- **Penetration Stage:** The pen tester attempts to gain access to the network/instances using different types of attacks such as SQL injection, cross-site

Amazon Seller Data Access

Best Practices



Key Security Control Guidance
Logging and Monitoring for Amazon SP-API Applications
Network Protection Guidance
Protect Amazon API Applications with Data Encryption
Protect Amazon API Applications with Data Retention and Recovery
Protect Amazon SP-API Applications with Incident Response
Safeguarding Sensitive Credentials

Vulnerability Management

A+ CONTENT API	
A+ Content API	>
A+ Content Examples	
AMAZON WAREHOUSING AND DISTRIBUTION API	
Amazon Warehousing and Distribution API	>
Amazon Warehousing and Distribution API v2024-05-09 Reference	
APP INTEGRATIONS API	
App Integrations API	>
APPLICATION MANAGEMENT API	
Application Management API	>
CATALOG ITEMS API	
Catalog Items API	>
Catalog Items API Rate Limits	
Catalog Items API v2022-04-01 Reference	
CUSTOMER FEEDBACK API	
Customer Feedback API	>
Customer Feedback API Rate Limits	

scripting, and back doors to exploit vulnerabilities.

- **Analysis/Report Stage:** The pen tester creates a report with detailed information about actions taken to penetrate network security and the vulnerabilities found. The pen tester must include a recommended actions section in the report.
- **Remediation/Clean up Stage:** The responsible team takes the lead and starts work on remediating vulnerabilities reported after the pen tests are completed.

After the remediation stage, solutions providers must run a second pen test to validate that all identified vulnerabilities have been completely remediated.

To learn more about how to apply pen tests at an application level and for network components such as firewalls and ports, refer to the [OWASP ZAP penetration test guide](#).

Code vulnerability scans

Mandatory code vulnerability scanning requirements help mitigate security risks when a new feature or product is being released. To ensure that there are no errors, technical issues, or security gaps when code is deployed, solution providers must conduct code vulnerability scans prior to every release.

The following is a list of code scanning tools:

- **Static Application Security Test (SAST):** Review of the code without having to run the code. SAST checks how the code is written to point out any security issues in it.
- **Dynamic Application Security Test (DAST):** In contrast to SAST, DAST checks the code in a running application by simulating attacks with malicious payload injections. DAST helps solutions providers to identify vulnerabilities within a running application.
- **Interactive Application Test (IAST):** IAST checks application functionalities across testing environments. This facilitates implementation and scalability as it helps to reduce possible downtime or service interruptions by tackling vulnerabilities prior to release.

DATA KIOSK

Data Kiosk API >

Data Kiosk Schema Explorer User Guide

Data Kiosk Query Processing Finished Notification

Building Data Kiosk workflows guide

Vendor Analytics Dataset Use Case Guide

Schedule Data Kiosk Queries

DELIVERY BY AMAZON API

Delivery by Amazon API >

EASY SHIP API

Easy Ship API >

EXTERNAL FULFILLMENT

External Fulfillment Inventory API >

External Fulfillment Returns API >

External Fulfillment Shipping API >

External Fulfillment Errors

External Fulfillment APIs Rate Limits

FULFILLMENT BY AMAZON (FBA)

FBA Inventory API >

FBA Inventory Dynamic Sandbox Guide

FEEDS API

These tools must follow the standards given by OWASP to check the application security against the top ten security risks. Solutions providers must scan code prior to release to identify, classify, and prioritize any security flaws that could affect or interrupt service.

Disaster recovery plan

To ensure that application users are not affected by incidents (technical or physical), solutions providers must develop remediation procedures on how to restore availability and access to PII data. These procedures must take into consideration Recovery Time Objective (RTO) and Recovery Point Objective (RPO). For more guidance, refer to [Establishing RTO and RPO Targets for Cloud Applications](#).

The following are definitions of RTO and RPO:

- **Recovery Time Objective (RTO):** The time it takes the solutions providers to restore normal service levels to application users. This can be accomplished by having redundancy within network instances/services that are critical for the application's functionality.
- **Recovery Point Objective (RPO):** The point in time where solutions providers can restore the data, in other words, the maximum acceptable data loss threshold during and after an incident. A fundamental aspect of this objective is to have one or more backups of the data in different locations, and perform those backups twice a week if possible.

Solutions providers are expected to use recovery strategies and test them to meet objectives (RTO and RPO). [AWS Resilience Hub](#) is an AWS service that helps to establish RTO and RPO targets, and it analyzes applications against those targets.

Key takeaways and next steps

- Implement vulnerability scans every 30 days, annual penetration tests, and code scans before each release to meet DPP compliance requirements.
- Address critical-risk vulnerabilities within 7 days and high-risk vulnerabilities within 30

Feeds API	>	days of discovery to minimize security exposure.
Feed Type Values	>	• Leverage Amazon security tools, such as Amazon Inspector and Amazon Guard. • Create and test procedures to restore PII access within hours, including maintaining geographically separated backup sites for business continuity. • Take the Amazon Data Protection Policy (DPP) Compliance Self-Check Assessment to evaluate your compliance status. • Keep detailed records of all vulnerability assessments, remediation actions, and security incidents to demonstrate ongoing DPP compliance during audits.
Feeds JSON Schemas	↗	
Feeds API Best Practices		
Feeds API FAQ		
Feeds API Rate Limits		

FINANCES

Finances API	>	Notices Amazon sellers and Solution providers are responsible for making their own independent assessment of the information in this document. This document: (a) is for informational purposes only, (b) represents current practices, which are subject to change without notice, and (c) does not create any commitments or assurances from Amazon.com Services LLC (Amazon) and its affiliates, suppliers, or licensors. Amazon Selling Partner API (Amazon SP-API) products or services are provided "as is" without warranties, representations, or conditions of any kind, whether express or implied. The responsibilities and liabilities of Amazon regarding SP-API are controlled by Amazon's SP-API agreements (including the Amazon Selling Partner API Developer Agreement or the Amazon Selling Partner API License Agreement), and this document is not part of, nor does it modify, any agreement between Amazon and any party.
Transfers API	>	
FULFILLMENT INBOUND API		
Fulfillment Inbound API	>	

 Updated 18 days ago

Fulfillment Inbound API FAQ		Safeguarding	A+ Content API	→
Migrating Fulfillment Inbound workflows		← Sensitive Credentials		
Fulfillment Inbound API Rate Limits				
FULFILLMENT OUTBOUND API				
Fulfillment Outbound Dynamic Sandbox Guide				
Fulfillment Outbound API	>			

Did this page help you? ☐ Yes ☐ No

Fulfillment Outbound API Rate Limits

MCF Best Practices

INVOICING

Invoices API >

Invoices API FAQ

LISTINGS

Listings Items API >

Listings Items API Rate Limits

Listings Restrictions API >

Listings Restrictions API Rate Limits

Manage Product Listings with the Selling Partner API

Building Listings Management Workflows Guide

Understanding Amazon listing status and seller-fulfilled inventory management

Listings Management Workflow Migration >

Manage Amazon Haul, Advanced Multiple-Offer, and Multiple-Fulfillment Use Cases

Listings APIs FAQ

Product Type Definitions API >

Product Type Definitions API Rate Limits

MERCHANT FULFILLMENT API

Merchant Fulfillment API >

MESSAGING API

Messaging API >

NOTIFICATIONS API

Notifications API >

Notification Type Values

Tutorial: Subscribe to the ORDER_CHANGE Notification ↗

ORDERS API

Orders API >

Tutorial: Retrieve and Pass a Purchase Order Number to a Carrier ↗

Orders API Migration Guide

Orders API Rate Limits

PRODUCT FEES API

Product Fees API >

PRODUCT PRICING API

Product Pricing API >

Product Pricing API and Notifications FAQ

Price Adjustment Automation Workflows Guide
Manage automated pricing rules with SP-API

REPLENISHMENT API

Replenishment API >

REPORTS API

Reports API >

Report Type Values >

Reports JSON Schemas ↗

Reports API FAQ

SALES API

Sales API >

SELLER WALLET API

Seller Wallet API >

Seller Wallet API Rate Limits

SELLERS API

Sellers API >

SERVICES API

Services API >

SHIPMENT INVOICING API

Shipment Invoicing API >

SHIPPING API

Shipping API v2 Resources ↗

Shipping API v1 Reference

SOLICITATIONS API

Solicitations API >

SUPPLY SOURCES API

Supply Sources API >

Multi-Location Inventory Integration Guide

Supply Sources API Rate Limits

TOKENS API

Tokens API >

UPLOADS API

Uploads API >

VEHICLES API

Vehicles API >

Vehicles API Rate Limits

VENDOR DIRECT FULFILLMENT APIS

Vendor Direct Fulfillment Dynamic Sandbox Guide

Vendor Direct Fulfillment Workflow Guide

SP-API Bill-to-Party Addresses

VENDOR DIRECT FULFILLMENT TRANSACTION STATUS API

Vendor Direct Fulfillment Transaction Status API >

VENDOR DIRECT FULFILLMENT INVENTORY API

Vendor Direct Fulfillment Inventory API >

VENDOR DIRECT FULFILLMENT ORDERS API

Vendor Direct Fulfillment Orders API >

VENDOR DIRECT FULFILLMENT SHIPPING API

Vendor Direct Fulfillment Shipping API >

VENDOR DIRECT FULFILLMENT PAYMENTS API

Vendor Direct Fulfillment Payments API >

VENDOR RETAIL PROCUREMENT INVOICES API

Vendor Retail Procurement Invoices API >

VENDOR RETAIL PROCUREMENT ORDERS API

Vendor Retail Procurement Orders API >

VENDOR RETAIL PROCUREMENT SHIPMENTS API

Vendor Retail Procurement Shipments API >

VENDOR RETAIL PROCUREMENT TRANSACTION STATUS API

Vendor Retail Procurement Transaction Status API >

